

Samuel Oliveira

Ph0enix



Github



LinkedIn



Website



HoneyLab: Relatório Técnico

Informações do documento:

Título	HoneyLab: Relatório Técnico
Cliente	Laboratório / Investigação
Autor	Samuel Oliveira
Data de realização	13/08/2026
Versão	1.0
Classificação	Confidencial

Controlo de Versões:

Versão	Data	Autor	Descrição
1.0	13/08/2026	Samuel Oliveira	Versão expandida

Distribuição:

Nome	Cargo	Organização
Samuel Oliveira	Autor	Laboratório



Índice

Introdução.....	5
O que é um Honeypot.....	6
Para que serve e quando é útil	7
Âmbito e Autorização.....	8
Ambiente Base e Sistema Operativo	8
Componentes de Captura (Defesa)	9
Cowrie: Honeypot SSH e Telnet.....	9
OpenCanary: FTP, HTTP e MySQL	10
SNARE e Tanner: Honeypot Web	11
Pipeline de Detecção e Análise (ELK)	12
Filebeat: Recolha e Envio de Logs	12
Logstash: Enriquecimento GeoIP e MITRE ATT&CK	13
Elasticsearch: Armazenamento e Pesquisa	14
Kibana: Visualização e Análise	14
ElastAlert 2: Alertas por Email	15
Como Tudo se Conecta: Visão Global	16
Painel de Controlo e Assistente de Configuração	17
Opção 0: Assistente de Configuração Inicial	18
Opções 1 a 4: Páginas e Interfaces.....	19
Opções 5 a 8: Logs em Tempo Real	19
Opção 9: Estado Detalhado dos Serviços	19
pt / en: Mudar o Idioma	19
Endurecimento e Segurança.....	20
Cowrie: Resistência à Detecção por nmap.....	20
Isolamento do Tanner: Sem Acesso ao Docker.....	21
Identidade Única e Sanitização para Template	21
Limitações Conhecidas.....	22
Detecção do Tanner (Ataques Web)	22
Dashboard Próprio do Tanner (Porta 8091)	23
Cowrie vs. ssh-audit	23
Empacotamento e Publicação	24
Metodologia de Análise.....	25
Recomendações Finais	25
Conclusão.....	26





Introdução

Este relatório documenta, ao pormenor técnico e de forma completa, o HoneyLab: um honeypot multi-serviço construído numa máquina virtual Ubuntu Server 26.04 LTS a correr sobre VMware. O documento foi escrito para poder ser lido tanto por quem nunca ouviu falar de honeypots como por um técnico de segurança: começa por explicar o que é e para que serve um honeypot, descreve cada componente de defesa e de análise (o que é, como funciona, que serviços tem e como está configurado), explica como tudo se liga de ponta a ponta, detalha o painel de administração opção a opção, expõe com total transparência as limitações conhecidas e termina com o processo de empacotamento e publicação.



O que é um Honeypot

Um honeypot (literalmente 'pote de mel') é um sistema-isco: um computador, serviço ou aplicação deliberadamente exposto e aparentemente vulnerável, cujo único propósito é atrair atacantes e registrar tudo o que eles fazem. Ao contrário de um servidor real, um honeypot não tem utilizadores legítimos nem serve para produção, por isso qualquer interação com ele é, por definição, suspeita: não há falsos positivos de tráfego normal. Tudo o que lá chega é reconhecimento, varrimento (scan) ou ataque.

Os honeypots classificam-se pelo nível de interação que oferecem ao atacante. Um honeypot de baixa interação apenas simula um serviço e regista as tentativas (por exemplo, aceita uma ligação FTP e anota o utilizador e a password tentados, mas não dá uma sessão real). Um honeypot de média interação emula parcialmente o serviço, deixando o atacante avançar mais (por exemplo, uma shell falsa onde ele executa comandos que são todos registados). Um honeypot de alta interação usa sistemas reais, o que dá dados riquíssimos mas com risco elevado de ser usado como trampolim para outros ataques. O HoneyLab combina baixa e média interação, o equilíbrio ideal entre riqueza de dados e segurança.

É importante distinguir um honeypot individual de uma honeynet: uma honeynet é uma rede inteira de honeypots. O HoneyLab é, na prática, uma mini-honeynet numa só máquina, porque expõe vários serviços-isco diferentes (SSH, Telnet, FTP, HTTP, MySQL e um site web) e centraliza a análise de todos eles.



Para que serve e quando é útil

Um honeypot cumpre vários papéis de segurança em simultâneo. O principal é funcionar como sistema de deteção precoce: como ninguém tem motivo legítimo para lhe tocar, o primeiro sinal de que alguém está a sondar a rede aparece muitas vezes primeiro no honeypot, antes de os sistemas reais serem atacados.

- Deteção precoce e alerta: identifica varrimentos e tentativas de intrusão logo no início, funcionando como um alarme silencioso.
- Inteligência de ameaças (threat intelligence): recolhe IPs de origem, credenciais mais tentadas, comandos executados, ferramentas descarregadas e táticas usadas, permitindo conhecer o adversário real.
- Distração e desgaste do atacante: enquanto o atacante perde tempo com o isco, os sistemas reais ficam mais protegidos e a equipa ganha tempo para reagir.
- Investigação e formação: é um ambiente seguro e isolado para estudar malware, analisar campanhas de ataque e treinar analistas de segurança, que é precisamente o objetivo deste laboratório.
- Deteção de movimento lateral interno: colocado dentro da rede, denuncia um atacante que já entrou e anda a explorar máquinas, uma vez que nenhum utilizador legítimo lhe acederia.

Um honeypot é especialmente útil em laboratórios de investigação e formação, em redes empresariais como sensor interno de alerta, e em qualquer cenário onde interesse estudar o comportamento dos atacantes sem pôr em risco sistemas de produção. Não substitui firewalls, antivírus ou sistemas de deteção de intrusão: complementa-os, acrescentando visibilidade sobre a intenção e as técnicas do adversário.



Âmbito e Autorização

O HoneyLab destina-se a ambiente de laboratório, formação e investigação. Durante o desenvolvimento corre numa rede isolada (NAT do VMware), sem exposição direta à Internet. A colocação em produção ou a exposição pública só é legítima mediante autorização escrita, âmbito (scope) definido, janela temporal acordada e um contacto de emergência.

As interfaces de gestão e análise não devem, em circunstância alguma, ser expostas publicamente. Isto inclui o serviço OpenSSH de gestão (porta 2222), o Kibana (porta 5601), o Elasticsearch (porta 9200) e o Logstash (portas 5044 e 9600). Apenas os serviços-isco devem ser alcançáveis pelo atacante.

Ambiente Base e Sistema Operativo

A base do sistema é uma máquina virtual VMware com Ubuntu Server 26.04 LTS. O hostname de gestão é 'honeypot' e a interface de rede principal é 'ens32'. Todos os serviços do honeypot são geridos por unidades systemd dedicadas, o que garante arranque automático, reinício em caso de falha e isolamento de privilégios por utilizador de serviço.

O acesso administrativo faz-se por SSH real (OpenSSH) na porta 2222 com o utilizador 'superadmin'. Esta separação (gestão na 2222, isco na 22) é essencial: a porta 22 é redirecionada por iptables para o honeypot Cowrie, pelo que o administrador nunca usa a porta 22 para gestão. No primeiro arranque, um serviço systemd ('regenerate-ssh-host-keys.service') regenera as chaves de host SSH, assegurando uma identidade criptográfica única por implantação.

A VM é fornecida como template pronto a usar. As credenciais de fábrica são: utilizador 'superadmin' com password 'honeypot01' (também usada para sudo) e utilizador do Elasticsearch 'elastic' com password 'changeme'. Não vem nenhum email de alertas configurado. Estas credenciais devem ser todas alteradas no primeiro uso, através do assistente do painel (opção 0), como se detalha mais à frente.



Componentes de Captura (Defesa)

A camada de captura é composta por três motores complementares, cada um cobrindo protocolos e níveis de interação distintos. São eles que o atacante vê e com que interage; tudo o que fazem é registrado e enviado para a pipeline de análise.

Cowrie: Honeypot SSH e Telnet

O que é: o Cowrie (versão 3.0.6, sobre a biblioteca Twisted / Twisted Conch 26.4.0) é um honeypot de média interação para os protocolos SSH e Telnet, os alvos mais comuns de ataques de força-bruta na Internet.

Como funciona: quando um atacante se liga, o Cowrie apresenta um banner e um pedido de login idênticos aos de um servidor real. Aceita (ou rejeita) credenciais e, se deixar entrar, apresenta uma shell falsa completa, com o hostname 'srv-storage-prod' e um sistema de arquivos falso onde o atacante pode navegar, executar comandos simulados e descarregar arquivos. Nada disto toca no sistema real: é tudo emulado. Cada tentativa de login (utilizador e password), cada comando introduzido, cada arquivo transferido (guardado e com hash) e todos os metadados de sessão são registados em formato JSON estruturado.

- Serviços e portas: escuta em 2223 (SSH) e 2224 (Telnet), portas não privilegiadas. Via iptables (NAT/PREROUTING) o tráfego de destino 22 é redirecionado para 2223 e o de 23 para 2224, pelo que o atacante vê as portas normais (22/23).
- Configuração, banner: apresenta 'SSH-2.0-OpenSSH_9.2p1 Debian-2+deb12u3', para simular um servidor Debian legítimo e atual (definido no cowrie.cfg).
- Configuração, execução: corre como serviço systemd ('cowrie'), sob um utilizador de serviço próprio sem privilégios de root; a instalação vive em '/home/cowrie/cowrie/' e os logs em JSON ('cowrie.json') são consumidos pelo Filebeat.
- Configuração, endurecimento: os algoritmos criptográficos SSH foram alinhados com os de um servidor moderno para o Cowrie não se denunciar ao nmap (ver secção de endurecimento).



OpenCanary: FTP, HTTP e MySQL

O que é: o OpenCanary é um honeypot de baixa interação que expõe vários serviços em simultâneo, cada um a fingir ser um serviço de rede legítimo, com o objetivo de capturar tentativas de acesso e de credenciais.

Como funciona: para cada serviço ativado, o OpenCanary abre a porta correspondente e responde o suficiente para o atacante pensar que é real, registando de imediato quem se ligou, de onde e com que credenciais. Não dá acesso real a nada. O identificador de nó (node_id) foi normalizado para 'opencanary-01' e todos os eventos são escritos em '/var/log/opencanary.log'.

- Serviço FTP (porta 21): apresenta um servidor de ficheiros falso e regista todas as tentativas de autenticação (utilizador e password).
- Serviço HTTP (porta 80): serve a página de login de um NAS falso, com a marca/skin 'DS-STORAGE-01', e captura as credenciais submetidas no formulário.
- Serviço MySQL (porta 3306): simula um servidor de base de dados e regista tentativas de ligação e de autenticação.
- Configuração e execução: definido no ficheiro de configuração do OpenCanary (quais os serviços ativos, portas e node_id); corre a partir de um ambiente virtual Python dedicado em '/opt/opencanary/venv', gerido por systemd; o log é consumido pelo Filebeat.



SNARE e Tanner: Honeypot Web

O que é: a dupla SNARE + Tanner é um honeypot web. O SNARE é o servidor que apresenta um site falso ao atacante; o Tanner é o cérebro que analisa cada pedido e decide como responder e como o classificar.

Como funciona: o SNARE serve um site web falso na porta 8080 e reencaminha cada pedido HTTP para o Tanner. O Tanner analisa o pedido, classifica-o quanto ao tipo de ataque (por exemplo SQL Injection, XSS ou RFI) e devolve uma resposta coerente, que o SNARE entrega ao atacante. Assim, o site parece vivo e reage aos ataques, ao mesmo tempo que os regista e classifica.

- Serviços e contentores: o Tanner corre em Docker, distribuído por cinco contentores: 'tanner' (motor de análise), 'tanner_api', 'tanner_web' (dashboard na porta 8091), 'tanner_redis' (estado e sessões) e 'tanner_phpox' (sandbox de execução PHP). Todos os contentores têm política de reinício automático.
- Configuração, orquestração: a stack do Tanner foi relocada para '/opt/honeypot/tanner/' (com o docker-compose em '/opt/honeypot/tanner/docker/docker-compose.yml'), fora das pastas pessoais, para que a mudança de nome do utilizador da VM nunca parta os caminhos montados nos contentores.
- Configuração, SNARE: corre como serviço systemd ('snare.service'), sob o utilizador 'superadmin', a partir de '/home/superadmin/snare'; aponta o Tanner em 127.0.0.1. Como o SNARE depende do Tanner (Docker), no arranque pode falhar até os contentores estarem prontos e recuperar sozinho através da política de reinício do systemd.
- Configuração, fluxo de dados: as classificações de ataque produzidas pelo Tanner são escritas em '/opt/honeypot/tanner/logs/tanner_report.json', que o Filebeat lê e envia para o Elasticsearch (índice 'honeypot-snare-*'). As limitações de deteção do Tanner estão detalhadas na secção de limitações.



Pipeline de Detecção e Análise (ELK)

Capturar os ataques é só metade do trabalho; a outra metade é transformar milhares de linhas de log em informação útil. Para isso, os eventos de todos os honeypots são centralizados numa pipeline ELK 8.x, que faz a recolha, o parsing, o enriquecimento, a indexação, a visualização e o alerta.

Filebeat: Recolha e Envio de Logs

O que é: o Filebeat é um agente leve de recolha de logs (um 'shipper'). A sua função é vigiar ficheiros de log e enviar cada linha nova para o passo seguinte, de forma fiável e com baixo consumo de recursos.

Como funciona: o Filebeat monitoriza continuamente os ficheiros de log dos três honeypots e, sempre que surge um evento novo, envia-o. Marca cada fonte com um campo identificador (por exemplo 'honeypot') que permite ao Logstash, a jusante, saber de que honeypot veio o evento e aplicar o processamento correto.

- Serviços/entradas monitorizadas: o log JSON do Cowrie ('/home/cowrie/cowrie/var/log/cowrie/cowrie.json'), o log do OpenCanary ('/var/log/opencanary.log') e o relatório do SNARE/Tanner ('/opt/honeypot/tanner/logs/tanner_report.json').
- Configuração: definida em '/etc/filebeat/filebeat.yml'; corre como serviço systemd e envia os eventos para o Logstash na porta 5044.



Logstash: Enriquecimento GeolP e MITRE ATT&CK

O que é: o Logstash é o motor de processamento e enriquecimento da pipeline. Recebe os eventos em bruto, interpreta-os e acrescenta-lhes informação de contexto antes de os guardar.

Como funciona: o Logstash faz o parsing de cada evento, adiciona geolocalização ao IP de origem através de uma base GeolP (MaxMind GeoLite2), o que permite saber de que país e cidade partiu o ataque, e aplica um mapeamento explícito para técnicas do referencial MITRE ATT&CK, etiquetando cada evento com a tática e a técnica correspondentes. No final, escreve o evento enriquecido no Elasticsearch.

- `cowrie.login.failed / login.success` -> T1110 (Brute Force, Credential Access).
- `cowrie.command.input` -> T1059 (Command and Scripting Interpreter, Execution).
- `cowrie.session.file_download` -> T1105 (Ingress Tool Transfer, Command and Control).
- Serviços e portas: entrada 'beats' na porta 5044 (onde recebe do Filebeat) e API de monitorização na porta 9600, ambas apenas locais.
- Configuração e indexação: definida em `/etc/logstash/conf.d/01-honeypot.conf`; os eventos são escritos em índices diários, `'honeypot-cowrie-*`, `'honeypot-opencanary-*` e `'honeypot-snare-*`. Este ficheiro contém a password do Elasticsearch, que o assistente atualiza automaticamente quando a password é alterada.



Elasticsearch: Armazenamento e Pesquisa

O que é: o Elasticsearch é a base de dados de pesquisa onde todos os eventos ficam guardados e indexados. É o coração de armazenamento da stack ELK.

Como funciona: indexa cada evento de forma a permitir pesquisas e agregações quase instantâneas sobre milhões de registos (por IP, país, serviço, técnica MITRE, data, etc.). É sobre estes índices que o Kibana desenha os gráficos e que o ElastAlert 2 avalia as regras de alerta.

- Serviços e portas: versão 8.x, nó único, com segurança e TLS ativos, exposto localmente em 'https://localhost:9200'. Como o TLS usa um certificado autoassinado, as chamadas locais usam a flag de confiança (curl -k).
- Configuração e credenciais: o utilizador administrativo é 'elastic', com a password padrão 'changeme' (de alteração obrigatória pelo assistente). A alteração da password é feita de forma segura pela ferramenta oficial 'elasticsearch-reset-password'.

Kibana: Visualização e Análise

O que é: o Kibana é a interface gráfica da stack ELK, e a superfície de análise principal do HoneyLab. É onde o analista vê, filtra e interpreta tudo o que foi capturado.

Como funciona: liga-se ao Elasticsearch e apresenta os dados em dashboards interativos. Autentica-se ao Elasticsearch por 'service account token' (e não pela password do utilizador 'elastic'), o que significa que os dashboards continuam a funcionar mesmo depois de a password do 'elastic' ser alterada pelo assistente.

- Serviços e portas: escuta na porta 5601; inclui a data view 'honeypot-*' que agrega os três índices.
- Configuração e conteúdo: traz um dashboard operacional ('Honeypot - Operational View') pré-construído, com mapa GeolP dos atacantes, top de IPs de origem, credenciais mais tentadas, comandos mais executados, distribuição por técnica MITRE ATT&CK e linha temporal de eventos.



ElastAlert 2: Alertas por Email

O que é: o ElastAlert 2 é o motor de alertas. Enquanto o Kibana é para consulta ativa, o ElastAlert 2 vigia os dados em contínuo e avisa por email quando deteta um padrão de ataque, sem ninguém ter de estar a olhar para o ecrã.

Como funciona: corre como serviço e, de forma periódica, faz pesquisas ao Elasticsearch à procura dos padrões definidos nas suas regras. Quando uma regra dispara, envia um email de alerta via SMTP do Gmail, usando uma App Password configurada pelo utilizador no assistente do painel.

- **cowrie-bruteforce**: deteta força-bruta SSH (por exemplo, 5 ou mais logins falhados do mesmo IP numa janela de 5 minutos).
- **opencanary-login**: deteta tentativas de credenciais nos serviços do OpenCanary (FTP/HTTP/MySQL).
- **snare-attack**: deteta pedidos web classificados como ataque pelo Tanner.
- **Configuração**: reside em '/etc/elastalert2/'; o ficheiro 'config.yaml' guarda a ligação e a password do Elasticsearch (atualizada pelo assistente), as regras estão em ficheiros próprios (cowrie-bruteforce, opencanary-login, snare-attack) e as credenciais de email em 'smtp_auth.yaml'. O destinatário e a App Password são escritos pelo assistente através do utilitário 'honeypot-set-email'.



Como Tudo se Conecta: Visão Global

O sistema funciona como uma cadeia contínua, do primeiro pacote do atacante até ao email de alerta na caixa de correio do administrador. O percurso é o seguinte:

- 1. Captura: o atacante liga-se a um serviço-isco, SSH/Telnet (Cowrie), FTP/HTTP/MySQL (OpenCanary) ou o site web (SNARE, que consulta o Tanner). O serviço regista a interação num ficheiro de log local.
- 2. Recolha: o Filebeat vigia esses ficheiros e envia cada evento novo para o Logstash (porta 5044).
- 3. Enriquecimento: o Logstash faz o parsing, acrescenta geolocalização (GeoIP) ao IP de origem e mapeia o evento para uma técnica MITRE ATT&CK.
- 4. Armazenamento: o evento enriquecido é indexado no Elasticsearch, no índice diário correspondente ('honeypot-cowrie/opencanary/snare-*').
- 5. Visualização: o Kibana lê esses índices e mostra tudo em dashboards (mapa, tops, técnicas, linha temporal), a superfície onde a análise é feita.
- 6. Alerta: em paralelo, o ElastAlert 2 avalia continuamente os mesmos dados e, quando um padrão de ataque dispara uma regra, envia um email de alerta ao administrador.

Todo este fluxo é local à VM (a análise não sai da máquina); só os alertas por email saem para o exterior. O painel de controlo, descrito a seguir, dá acesso rápido a cada peça desta cadeia.



Painel de Controlo e Assistente de Configuração

Ao iniciar sessão (na consola da VM ou por SSH), é apresentado automaticamente um painel de controlo em shell. Isto é conseguido pelo perfil de shell (via `PROMPT_COMMAND`), que invoca o script instalado em `'/usr/local/bin/honeypot-panel'`. O painel mostra, no topo, um cabeçalho com o IP da VM, a data e a hora; caso a configuração inicial ainda não esteja concluída, mostra também um aviso vermelho a listar exatamente o que falta configurar.

Estado dos serviços: logo abaixo, o painel mostra o estado (ativo/parado, a verde ou vermelho) de cada componente, Cowrie, OpenCanary, SNARE, Kibana, Elasticsearch e o contentor Tanner, para uma verificação de saúde imediata. O painel é totalmente bilingue (Português/Inglês) e o idioma fica guardado por utilizador no ficheiro `'~/.honeypot-lang'`. Segue-se a descrição de todas as opções.



Opção 0: Assistente de Configuração Inicial

Escrevendo '0' (ou 'setup') abre-se o assistente de primeira configuração. Ele deteta de forma real o estado de cada item e marca-o como PENDENTE (vermelho) ou CONCLUÍDO (verde, com a data da última alteração). São quatro itens; cada um pede a password de administrador antes de permitir alterações, e em qualquer submenu se pode escrever '0' para voltar atrás. Enquanto houver itens pendentes, o aviso vermelho do painel persiste; quando os quatro ficam concluídos, é criada a flag '/etc/honeypot-panel/.setup_done'.

- Item 1, Trocar o username da VM: pede o novo nome de utilizador (não pode ser 'root', nem o nome de fábrica 'superadmin', nem repetir um já existente). Como não é seguro renomear um utilizador com sessão aberta, a alteração é agendada para o próximo arranque e a VM reinicia; ao voltar, entra-se com o novo username e a mesma password. Um serviço de arranque renomeia o utilizador e atualiza todas as referências (sudoers, SNARE, Filebeat, painel).
- Item 2, Trocar a password da VM: pede a nova password (não pode ficar vazia nem ser a de fábrica 'honeypot01') e aplica-a de imediato ao utilizador atual.
- Item 3, Trocar a password do Elasticsearch: pede a nova password (não pode ser a de fábrica 'changeme'), redefine-a com a ferramenta oficial e propaga-a automaticamente para o Logstash e o ElastAlert 2, reiniciando esses serviços para a mudança ter efeito.
- Item 4, Configurar o email de alertas: pede o email do Gmail onde queres receber os alertas e a respetiva App Password de 16 caracteres (gerada na conta Google). O assistente valida o email, valida o formato da App Password e faz um teste de login SMTP real ao Gmail antes de gravar; só grava se o login for bem-sucedido. A partir daí, o email fica associado às três regras do ElastAlert 2 e passa a aparecer no próprio assistente como 'Email configurado'.



Opções 1 a 4: Páginas e Interfaces

Estas opções mostram o endereço a abrir no browser do teu computador (host) para aceder a cada interface web (o painel não abre um browser dentro da VM; indica o URL, usando o IP da VM). Escreve o número e carrega Enter; para voltar ao painel, Enter.

- Opção 1, Visualizar o site falso (SNARE): abre o site-isco em 'http://IP:8080', o que o atacante vê.
- Opção 2, Analisar o painel admin falso (OpenCanary): abre a página de login do NAS falso em 'http://IP:80'.
- Opção 3, Visualizar os Kibana Dashboards: abre o Kibana em 'http://IP:5601' (autentica com 'elastic' e a password do Elasticsearch). É aqui que se faz a análise.
- Opção 4, Dashboard de análise web do Tanner: abre a interface do Tanner em 'http://IP:8091' (ver, nas limitações, porque as contagens desta página ficam a zero).

Opções 5 a 8: Logs em Tempo Real

Estas opções mostram os logs a correr ao vivo, diretamente no terminal, para se ver o que está a acontecer no momento. Escreve o número e carrega Enter; para sair e voltar ao painel, carrega Ctrl + C.

- Opção 5, Logs do Cowrie: atividade SSH / Telnet (logins e comandos).
- Opção 6, Logs do OpenCanary: atividade FTP / HTTP / MySQL.
- Opção 7, Logs do SNARE: pedidos ao site falso.
- Opção 8, Logs do Tanner: análise e classificação dos ataques web.

Opção 9: Estado Detalhado dos Serviços

Escrevendo '9' mostra-se um estado detalhado: o estado (Active) de cada serviço systemd (Cowrie, OpenCanary, SNARE, Kibana, Elasticsearch) e a lista dos contentores Docker do Tanner com o respetivo estado. Serve para diagnóstico rápido. Carrega Enter para voltar ao painel.

pt / en: Mudar o Idioma

Escrevendo 'pt' ou 'en' no painel muda-se o idioma de toda a interface (painel e assistente) para Português ou Inglês. A escolha fica guardada no ficheiro '~/.honeypot-lang' e é lembrada nas sessões seguintes.



Endurecimento e Segurança

Cowrie: Resistência à Detecção por nmap

Por defeito, o Cowrie denuncia-se: anuncia um banner de OpenSSH moderno mas oferece um conjunto de algoritmos criptográficos antigos e inconsistentes (por exemplo 3des-cbc, cast128-cbc, cifras em modo CBC, MACs hmac-sha1/hmac-md5 e trocas de chave em -sha1). Ferramentas como o 'nmap' (script ssh2-enum-algos) e o 'ssh-audit' detetam esta incoerência de imediato e identificam a emulação. Para eliminar esta assinatura, os algoritmos oferecidos foram alinhados com os de um servidor moderno e endurecido, editando a secção [ssh] do 'cowrie.cfg':

- Cifras (ciphers): aes256-ctr, aes192-ctr, aes128-ctr (sem CBC, 3DES ou CAST128).
- MACs: hmac-sha2-512, hmac-sha2-256 (sem hmac-sha1 nem hmac-md5).
- Troca de chaves (kex): curve25519-sha256, curve25519-sha256@libssh.org, ecdh-sha2-nistp256/384/521 e diffie-hellman-group-exchange-sha256 (sem variantes SHA1).
- Compressão: none, zlib@openssh.com.

Como o Cowrie não expunha nativamente a opção de KEX ao motor do Twisted, foi necessário aplicar um pequeno patch ao 'factory.py' do Cowrie para que passasse a ler a chave '[ssh] kex'. O resultado quebra a assinatura clássica do Cowrie e derrota um 'nmap -sV/ssh2-enum-algos', sem qualquer perda de performance nem de capacidade de captura (verificado: logins e comandos continuam a ser registados e a chegar ao Elasticsearch).



Isolamento do Tanner: Sem Acesso ao Docker

Alguns emuladores do Tanner (nomeadamente LFI, command injection e template injection) exigem acesso ao socket do Docker para lançarem contentores auxiliares (Docker-in-Docker). Num honeypot, montar o socket do Docker num contentor exposto ao atacante seria um risco crítico: permitiria a fuga do contentor e a obtenção de privilégios de root no anfitrião. Por decisão de segurança deliberada, esses emuladores permanecem desativados, uma limitação funcional assumida em favor da segurança do host.

Identidade Única e Sanitização para Template

Para que cada implantação do template seja distinta e não partilhe segredos, o processo de empacotamento inclui o script 'honeypot-sanitize-final.sh', que remove as chaves de host SSH, o machine-id, os históricos de shell, as chaves SSH autorizadas e conhecidas (authorized_keys, known_hosts), o estado de HSTS, os BSSIDs de rede Wi-Fi, os artefactos do cloud-init, a cache do apt e a totalidade dos logs, deixando o sistema limpo. As chaves de host SSH são depois regeneradas de forma única no primeiro arranque pelo serviço systemd dedicado.



Limitações Conhecidas

Por transparência total, esta secção descreve o que não funciona a 100% e as respetivas causas técnicas exatas.

Deteção do Tanner (Ataques Web)

O Tanner deteta de forma fiável três classes de ataque, SQL Injection (SQLi), Cross-Site Scripting (XSS) e Remote File Inclusion (RFI), que são registadas no Kibana com a respetiva classificação (índice 'honeypot-snare-*'). Os restantes tipos não são detetados de forma fiável, pelas seguintes razões técnicas:

- LFI, command injection e template injection: os emuladores respetivos exigem o socket do Docker e estão desativados por segurança (ver secção de endurecimento); ativá-los chega inclusivamente a provocar o crash do Tanner pela ausência desse acesso.
- PHP code injection: é classificado como XSS, porque o payload '<?php ... ?>' contém os caracteres '<' e '>' e o padrão (regex) de deteção de XSS do Tanner, mais abrangente, tem prioridade sobre o de PHP.
- CRLF injection: não é injetável de forma fiável por URL, porque a camada HTTP sanitiza os caracteres de retorno de carro e nova linha (\r\n).
- XXE (XML External Entity): exige o parsing de um corpo POST em XML, que o Tanner não realiza sobre pedidos simples.
- PHP object injection: depende de um formato/encoding de payload específico que os pedidos genéricos de teste não satisfazem.



Dashboard Próprio do Tanner (Porta 8091)

A página de estatísticas por sessão do Tanner (porta 8091) apresenta o valor zero mesmo quando existem ataques detetados. A causa é a divergência de versões ('version drift') entre as imagens 'mushorg/tanner:latest' e 'mushorg/redis:latest': o cliente redis é incompatível (o argumento 'encoding' foi removido em versões recentes), as assinaturas dos emuladores estão desalinhadas com o 'base.py' e o agregador de sessões ('session_analyzer') não preenche o campo de contagem de ataques ('attack_count'). É importante sublinhar: os ataques SÃO detetados e CHEGAM ao Kibana (com classificação); a análise real faz-se no Kibana. A página 8091 é uma interface secundária do Tanner que ficou parcialmente inoperacional.

Cowrie vs. ssh-audit

Contra o 'nmap', a deteção está resolvida. Contra um 'ssh-audit' dedicado, o Cowrie não é 100% indistinguível de um servidor real: a biblioteca Twisted (usada pelo Cowrie) não implementa os algoritmos mais modernos (chacha20-poly1305, cifras AES-GCM) nem anuncia 'rsa-sha2-*' como algoritmo de chave de host. Um analista atento nota 'servidor endurecido, mas sem os cifradores AEAD modernos'. Fechar esta lacuna exigiria um patch arriscado à biblioteca Twisted ou colocar um OpenSSH real como front-end (numa configuração de intermediação/MITM), ambas as opções foram rejeitadas por comprometerem a estabilidade e a fiabilidade da captura.



Empacotamento e Publicação

Depois de a VM estar configurada e testada, foi preparada para distribuição como template pronto a usar. O processo teve três fases: sanitização, exportação e distribuição/publicação.

Sanitização e exportação: com a VM ligada, correu-se o 'honeypot-sanitize-final.sh' (que apaga chaves de host SSH, machine-id, históricos, logs e outros rastros, deixando o sistema em estado de fábrica) e desligou-se a máquina de forma limpa. No VMware, com a VM desligada, consolidaram-se/apagaram-se os snapshots, fez-se o 'Compact' do disco '.vmdk' (para reclamar o espaço livre) e exportou-se a VM para um único ficheiro OVA ('HoneyLab.ova'). Nota importante: não se usa zero-fill agressivo com 'dd' antes do Compact, porque pode fazer crashar o gestor de I/O do VMware Workstation; o próprio Compact já reclama os blocos livres.

Distribuição num único ficheiro: o OVA exportado tem cerca de 5,7 GB e, como o disco dentro do OVA já vem comprimido, a compressão adicional é praticamente irrelevante (uma recompressão reduz apenas cerca de 1%). Por isso, em vez de dividir a VM em vários volumes, distribui-se o 'HoneyLab.ova' como um único ficheiro através de um serviço de nuvem gratuito (MEGA), cuja conta gratuita (20 GB) não impõe qualquer limite de 2 GB por ficheiro. Opcionalmente, disponibiliza-se também o mesmo OVA dentro de um único arquivo '.zip' (que reduz apenas cerca de 1%, mas dá uma verificação de integridade automática ao extrair). Publica-se ainda o checksum SHA256 do ficheiro, para o utilizador confirmar que o download não ficou corrompido.

Publicação: o repositório do GitHub aloja o código-fonte (painel, assistente, utilitários e scripts), o guia de utilização (README) e este relatório técnico. A VM em si ('HoneyLab.ova', ~5,7 GB) é disponibilizada através de uma ligação externa de nuvem gratuita (MEGA), por exceder o limite de 100 MB por ficheiro do GitHub. Para usar, o utilizador descarrega o 'HoneyLab.ova' (ou o 'HoneyLab.zip' e extrai-o), confirma opcionalmente o SHA256, importa o OVA no VMware (rede em NAT para laboratório) e liga a VM.



Metodologia de Análise

Para analisar um incidente capturado recomenda-se a seguinte metodologia: (1) no Kibana, filtrar por IP de origem, serviço ou técnica MITRE ATT&CK; (2) reconstruir a linha temporal completa da sessão (login, sequência de comandos, downloads); (3) correlacionar com a geolocalização (GeoIP) e o user-agent; (4) para ataques web, consultar a classificação atribuída pelo Tanner no índice 'honeypot-snare-*'; (5) validar e contextualizar com os alertas gerados pelo ElastAlert 2. Recomenda-se manter, no mínimo, 7 dias de dados para obter métricas e tendências significativas.

Recomendações Finais

- Concluir o assistente de configuração inicial (opção 0) antes de qualquer utilização real: trocar o username da VM, trocar a password da VM, alterar a password do Elasticsearch e configurar o email de alertas.
- Nunca expor à Internet as portas de gestão (SSH 2222), Kibana (5601), Elasticsearch (9200) ou Logstash (5044/9600); apenas os serviços-isco devem ser alcançáveis.
- Rever periodicamente os dashboards do Kibana e os alertas do ElastAlert 2; definir políticas de rotação e retenção de índices.
- Para a análise de ataques web, usar o Kibana e não a página 8091 do Tanner.
- Nunca conceder ao contentor do Tanner (nem a qualquer serviço-isco) acesso ao socket do Docker.
- Antes de exportar como template, correr sempre o 'honeypot-sanitize-final.sh' e desligar a VM de forma limpa; não voltar a arrancar a VM antes de a exportar.



Conclusão

O HoneyLab implementa uma cadeia completa e funcional de captura (Cowrie, OpenCanary, SNARE/Tanner), detecção, enriquecimento (GeoIP e MITRE ATT&CK), visualização (Kibana) e alerta (ElastAlert 2), com um endurecimento efetivo do Cowrie contra a detecção por nmap e um painel de gestão próprio, bilingue e com assistente de configuração. As limitações existentes estão documentadas com total transparência e decorrem, na sua maioria, de restrições de segurança deliberadas (isolamento do Docker) ou de divergências de versões em componentes de terceiros (Tanner/Redis), não afetando a capacidade central de captura e análise, que é assegurada de forma robusta pela pipeline ELK/Kibana.

Obrigado

Ph0enix



Github



LinkedIn



Website